

A2A Threat Model — Gold Example

Worked for Pod 04 · SettleNet (A2A payments reconciliation) · hand out after the debrief

The one idea to leave with: in a multi-agent system the danger is rarely a hacker breaking in — it's **untrusted data crossing a trust boundary and becoming an instruction** that reaches a privileged agent. Privilege separation only holds if identities and inputs are actually separated.

1–2 · Agents & privileges

AGENT	RUN BY	CAN DO	PRIVILEGE
Orchestrator	Meridian	Coordinates agents; passes messages between them	Medium
Reconciliation / query agent	Meridian	Reads ledgers and statements	Low–Med
Vendor agent	Vendor (external)	Exchanges reconciliation data over A2A	Low, but attacker-reachable
Posting agent ★	Meridian	Executes ledger entries / payments (wire, RTP, ACH)	High

Highest-privilege action (★): `execute_payment` / `post_ledger_entry` — irreversible, especially over RTP.

3 · Trust boundary

INSIDE (MERIDIAN CONTROLS)	OUTSIDE (UNTRUSTED)
Orchestrator, reconciliation agent, posting agent	Vendor agent and every message / data field it supplies; counterparty data

4 · The worst path

Vendor agent (outside the boundary)

- sends a crafted reconciliation message
- orchestrator appends it to the shared context as if trusted
- the embedded instruction reaches the posting agent (confused deputy / XPiA)
- posting agent runs **execute_payment** → **attacker**
- over RTP, the payment is **irreversible**

No “break-in” anywhere — just untrusted vendor data treated as an instruction, then handed to the one agent that can move money.

5 · Controls (smallest first)

- **Fence untrusted input:** vendor messages are *data*, never instructions — schema-validate, don't pass free text into the posting agent.

- **Human checkpoint** on the posting agent for irreversible or over-threshold payments.
- **Separate non-human identities:** the posting agent's credentials are unreachable by the query or vendor agents.
- **Amount / rate limits + dry-run** before any live posting.

HOW OTHER PODS ADAPT THE SAME FIVE STEPS

- **Navigator (03):** ★ = account action; boundary = the customer chat field; path = injected chat → irreversible action.
- **ClearList (01):** ★ = auto-close; boundary = alert/case content; path = crafted transaction text → wrongful clear.
- **MemoWriter (02):** ★ = the credit decision the draft shapes; boundary = borrower documents.
- **Second Line (05):** ★ = the copilot's sign-off; boundary = the model docs it ingests.
- **Compass (06):** ★ = the recommendation; boundary = market data and external "house views."

Illustrative for the exercise only. A real threat model is broader and bank-specific. This is a 25-minute scaffold, not a complete security assessment.